Orange Digital Center

SNORT LAB

Détection d'intrusion : ping, HTTP, scan SYN, FTP et brute force SSH

Compte rendu de travaux pratiques

Réalisé par : **Hawa Kane**

Orange Digital Center – Novembre 2026

Résumé

Ce rapport présente un laboratoire de détection d'intrusion avec Snort. Snort est installé sur une machine Ubuntu, qui joue à la fois le rôle de cible et de surveillant : c'est elle qui est attaquée, et c'est elle qui fait tourner Snort pour s'en apercevoir. Une machine Kali Linux sert d'attaquant : elle envoie cinq types de trafic suspect (ping, requête HTTP suspecte, scan de ports, connexion FTP, force brute SSH) pour vérifier que chaque règle déclenche bien une alerte.

Ce document est réalisé à des fins pédagogiques, dans un environnement de laboratoire isolé et avec l'autorisation de l'encadrant.

1. Objectif du laboratoire

Le but est d'écrire cinq règles Snort, chacune correspondant à un type d'attaque, puis de vérifier qu'elles fonctionnent réellement en envoyant cette attaque depuis Kali. Les cinq scénarios sont :

- Ping (ICMP) : une machine sonde la présence d'un hôte ;
- Trafic HTTP suspect : une tentative d'accès au fichier /etc/passwd via le port 80 ;
- Scan SYN : un scan de ports réalisé avec Nmap ;
- Tentative de connexion FTP : une connexion sur le port 21 ;
- Brute force SSH : plusieurs tentatives de connexion rapprochées sur le port 22.

2. Les deux machines du laboratoire

Machine	Rôle	Adresse IP	Interface
Ubuntu	Cible ET surveillant : Snort y est installé	192.168.222.130	ens33
Kali Linux	Attaquant : envoie le trafic suspect	192.168.222.128	eth0

Il n'y a que deux machines dans ce laboratoire. Ubuntu joue les deux rôles à la fois : c'est la maison qu'on protège, et c'est aussi là qu'on installe l'alarme (Snort). Kali ne sert qu'à simuler un attaquant extérieur ; aucune configuration de sécurité n'y est faite, elle ne fait qu'envoyer du trafic. Les deux machines doivent être sur le même réseau pour se voir : ici, les trois premiers nombres de leur adresse sont identiques (192.168.222), seul le dernier change.

Les adresses IP sont attribuées automatiquement (DHCP) et peuvent changer d'une session à l'autre : avant de relancer un test, il faut toujours vérifier l'adresse actuelle de chaque machine.

3. Préparation des deux machines

3.1 Identifier l'interface et l'adresse de chaque machine

Sur chaque machine, la commande `ip a` affiche le nom de la carte réseau (l'interface) et l'adresse IP qui lui est attribuée. C'est la toute première chose à faire, avant même d'installer Snort, car ces informations seront réutilisées à chaque étape suivante.

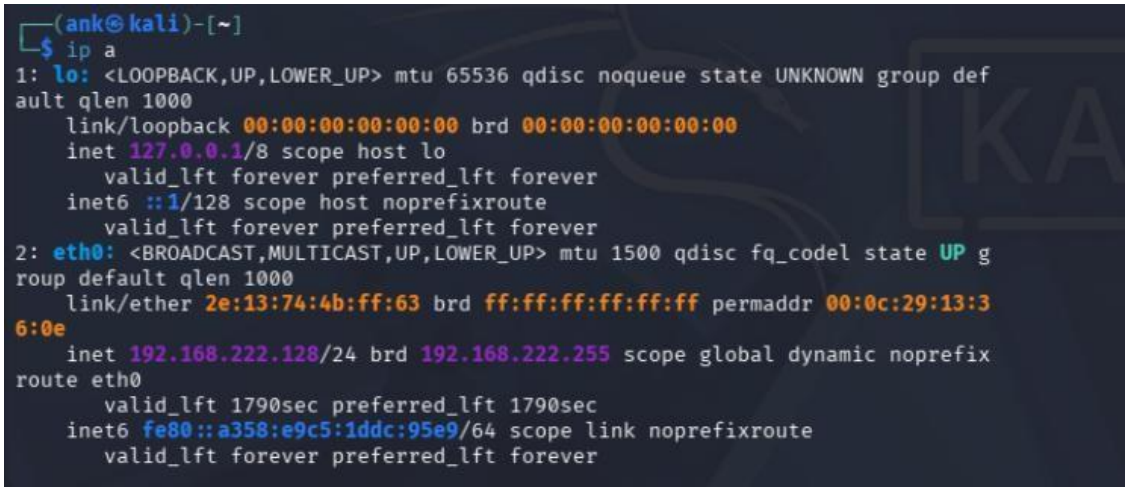


Figure 1 : résultat de « ip a » sur Kali

Sur cette capture, Kali utilise l'interface eth0 et a reçu l'adresse 192.168.222.128. C'est l'adresse qui apparaîtra comme source de chaque attaque dans les alertes Snort.

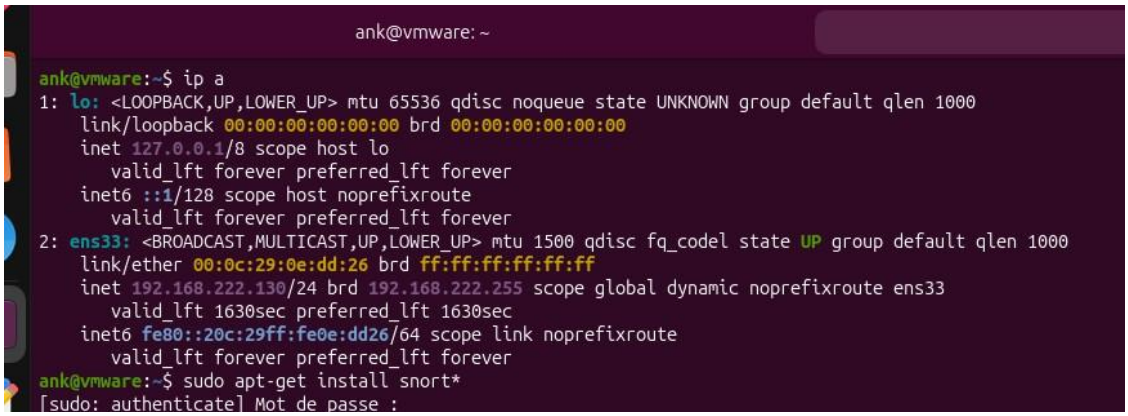


Figure 2 : résultat de « ip a » sur Ubuntu

Sur Ubuntu, l'interface s'appelle ens33 et son adresse est 192.168.222.130. C'est l'adresse de la machine à protéger : c'est elle qui sera indiquée à Snort un peu plus loin, dans la variable HOME_NET.

3.2 Installer Snort sur Ubuntu

Snort s'installe avec la commande `sudo apt-get install snort`sur Ubuntu uniquement (Kali n'a pas besoin de Snort, puisqu'il ne fait qu'attaquer). Pendant l'installation, deux questions sont posées : le nom de l'interface à surveiller (ens33) et la plage d'adresses du réseau local à protéger, à indiquer au format CIDR, par exemple 192.168.222.0/24.

Quand l'installateur demande ensuite s'il doit garder ou remplacer les fichiers de configuration déjà présents (snort.conf, snort.debian.conf...), on répond toujours N (garder sa propre version), puisque c'est justement celle qu'on vient de personnaliser avec sa propre adresse réseau.

```
ank@vmware:~$ sudo apt-get install snort*
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Note : sélection de snort-rules pour l'expression rationnelle « snort* »
Note : sélection de « oinkmaster » au lieu de « snort-rules »
Résolution des dépendances  ... Fait
Les NOUVEAUX paquets suivants seront installés :
  oinkmaster
0 mis à jour, 1 nouvellement installés, 0 à enlever et 128 non mis à jour.
Il est nécessaire de prendre 71,1 ko dans les archives.
Après cette opération, 257 ko d'espace disque supplémentaires seront utilisés.
Réception de : 1 http://sn.archive.ubuntu.com/ubuntu resolute/universe amd64 oinkmaster all 2.0-5 [71,1 kB]
71,1 ko réceptionnés en 1s (82,8 ko/s)
Sélection du paquet oinkmaster précédemment désélectionné.
(Lecture de la base de données... 199817 fichiers et répertoires déjà installés.)
Préparation du dépaquetage de .../oinkmaster_2.0-5_all.deb ...
Dépaquetage de oinkmaster (2.0-5) ...
Paramétrage de oinkmaster (2.0-5) ...
Traitement des actions différées (« triggers ») pour man-db (2.13.1-1build1) ...
```

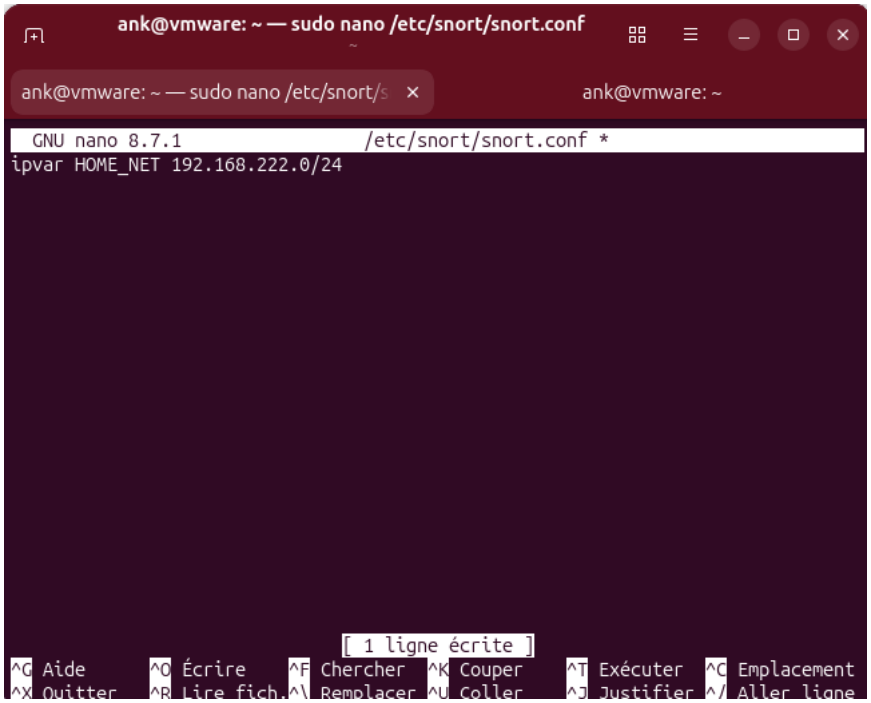
4. Configurer Snort et écrire les règles

Deux fichiers sont à connaître : /etc/snort/snort.conf, qui contient les réglages généraux de Snort, et /etc/snort/rules/local.rules, qui contient les règles de détection personnalisées.

4.1 Régler la variable HOME_NET

Dans snort.conf, la variable HOME_NET indique à Snort quelle machine il doit surveiller. Comme c'est Ubuntu qui reçoit les attaques, HOME_NET doit correspondre à son réseau : ipvar HOME_NET 192.168.222.0/24.

Un point important, facile à oublier : Snort a aussi besoin de savoir où se trouve le dossier des règles. Il faut donc ajouter la ligne var RULE_PATH /etc/snort/rules avant la ligne qui charge local.rules. Sans cette ligne, Snort refuse de démarrer et affiche une erreur « Undefined variable name: RULE_PATH ».



4.2 Écrire les cinq règles

Le fichier local.rules s'ouvre avec `sudo nano /etc/snort/rules/local.rules`.

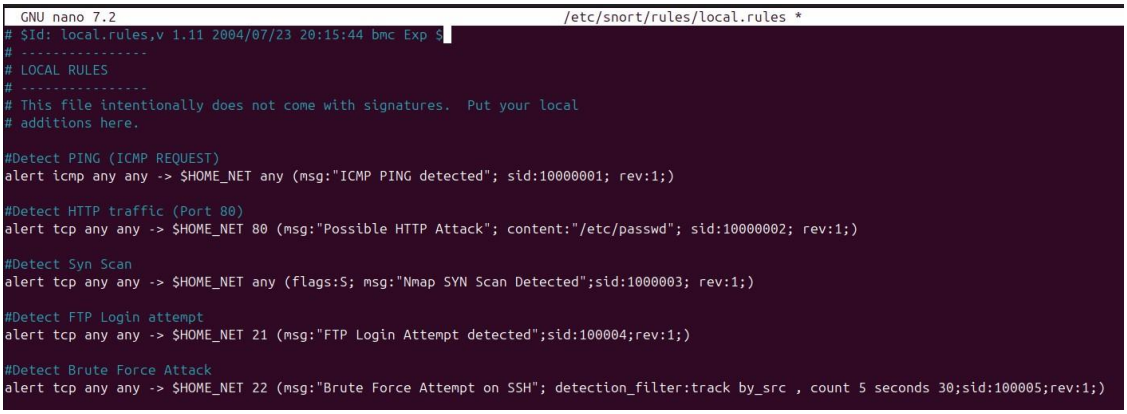


Figure 3 : contenu du fichier local.rules ouvert dans nano

La capture ci-dessus montre les cinq règles telles qu'elles ont été écrites dans le fichier. Chaque règle commence par un commentaire (la ligne avec #) qui rappelle ce qu'elle détecte, puis la ligne alert elle-même. Voici ce que chacune signifie :

- ICMP PING detected : se déclenche sur tout paquet ICMP (ping) reçu par Ubuntu, quelle que soit sa provenance.
- Possible HTTP Attack : se déclenche quand une requête vers le port 80 contient le texte « /etc/passwd », ce qui trahit une tentative d'accès à un fichier sensible du système.
- Nmap SYN Scan Detected : se déclenche sur un paquet TCP qui n'a que le drapeau SYN activé, signe d'un scan de ports (la connexion n'est jamais terminée).
- FTP Login Attempt detected : se déclenche dès qu'une connexion arrive sur le port 21, celui du FTP.
- Brute Force Attempt on SSH : se déclenche quand 5 paquets ou plus, venant de la même adresse, arrivent sur le port 22 (SSH) en moins de 30 secondes. C'est la seule règle qui compte plusieurs paquets avant d'alerter, grâce à l'option detection_filter ; les quatre autres alertent dès le premier paquet correspondant.

Chaque règle se termine par un numéro sid unique (identifiant de la règle) : pour une règle qu'on écrit soi-même, ce numéro doit toujours être supérieur ou égal à 1000000.

5. Lancer Snort

Snort se lance avec la commande `sudo snort -A console -q -c /etc/snort/snort.conf -i ens33 -l /var/log/snort`, exécutée sur Ubuntu.



Figure 4 : lancement de Snort sur Ubuntu

Une fois cette commande lancée, le terminal ne revient plus à l'invite de commande : c'est normal, cela ne veut pas dire que la commande est bloquée ou plantée, mais que Snort est en train d'écouter en continu. Il faut laisser ce terminal ouvert et visible, sans rien y taper, pendant qu'on va faire les tests depuis Kali. Toute alerte apparaîtra directement dans cette même fenêtre.

6. Les cinq tests d'attaque, depuis Kali

Pour chaque test, Snort doit déjà être lancé et actif sur Ubuntu (partie 5). On se place ensuite sur Kali pour envoyer l'attaque, puis on revient regarder la fenêtre Snort pour voir l'alerte apparaître.

6.1 Ping (ICMP)

Depuis Kali, on envoie quatre paquets vers Ubuntu avec `ping -c 4 192.168.222.130`.

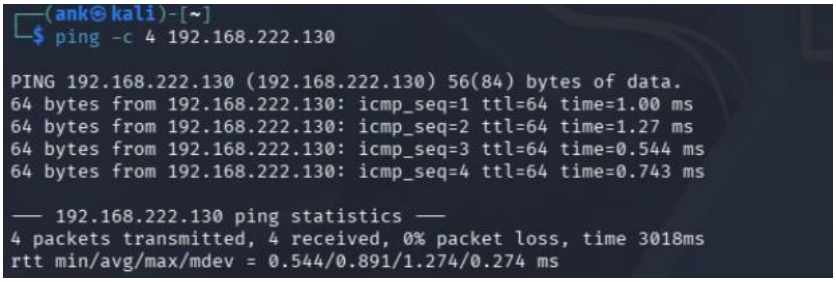


Figure 5 : réponse au ping depuis Kali

Cette première capture montre que les quatre paquets sont bien arrivés et qu'Ubuntu a répondu (0% de perte) : la communication entre les deux machines fonctionne.



Figure 6 : alertes générées par Snort pendant le ping

Sur Ubuntu, Snort affiche une ligne d'alerte pour chaque paquet ICMP échangé, dans les deux sens (la requête de Kali vers Ubuntu, et la réponse d'Ubuntu vers Kali). Le message ICMP PING detected confirme que la règle n°1 fonctionne, et on retrouve bien les deux adresses IP des deux machines dans chaque ligne.

- snort ne recevait pas d'alertes car y'avait des lignes qui manquaient sur le fichier de configuration /etc/snort/snort.conf



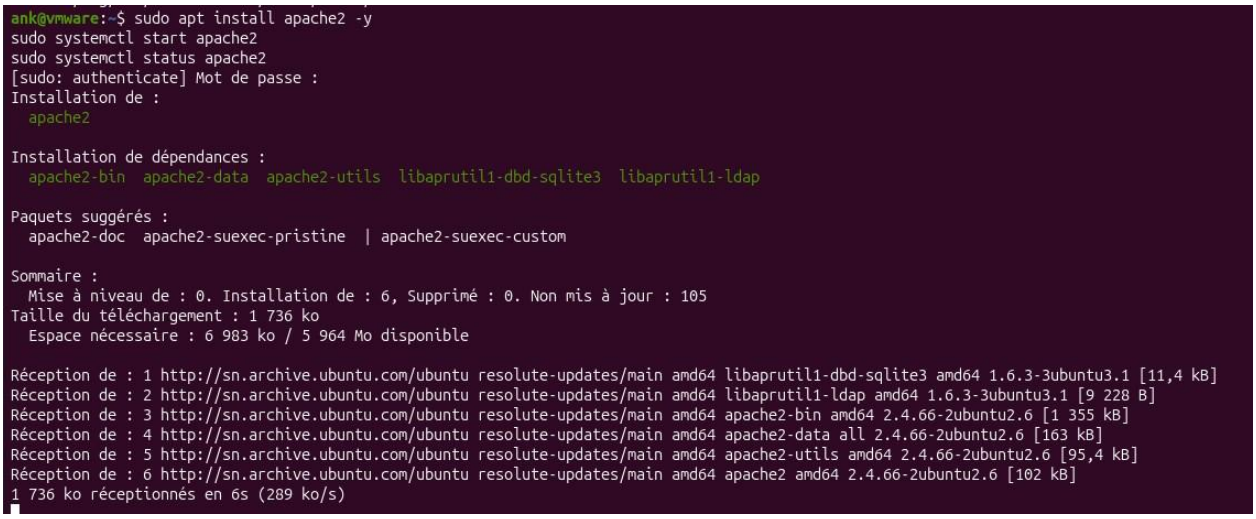
6.2 Trafic HTTP suspect

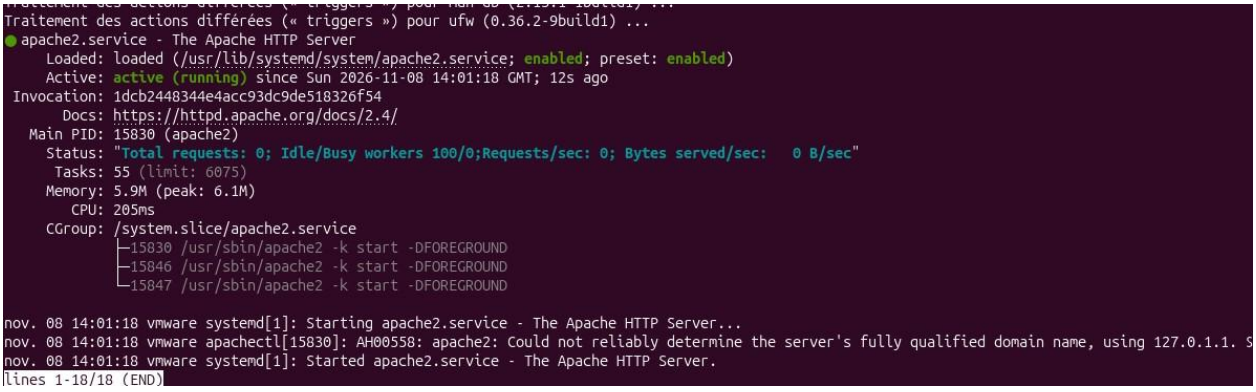
Depuis Kali, on tente d'accéder au fichier /etc/passwd via le port 80 avec `curl http://192.168.222.130:80/../../../../../../../etc/passwd`.



Figure 7 : réponse du serveur à la requête curl

Cette capture montre une erreur de connexion ou une page d'erreur : c'est normal, et ce n'est pas grave pour le test. Cela indique qu'il n'y a aucun serveur web (Apache) installe sur ubuntu. • On l'installe sur ubuntu





- On relance alors la commande curl sur kali



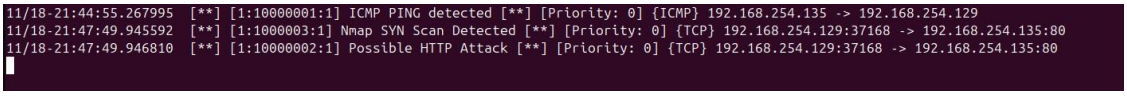


Figure 8 : alerte Possible HTTP Attack générée par Snort

La ligne Possible HTTP Attack confirme que Snort a bien vu passer la tentative, même si elle n'a abouti à rien côté serveur. Cela montre une chose importante : Snort surveille le réseau, pas le résultat final de l'attaque.

6.3 Scan de ports SYN (Nmap)

Depuis Kali, on lance un scan sur tous les ports d'Ubuntu avec `nmap -sS 192.168.222.130`.



Figure 9 : résultat du scan Nmap

Nmap indique ici quels ports sont ouverts sur Ubuntu. Pendant ce scan, un paquet SYN est envoyé sur chacun des ports testés.

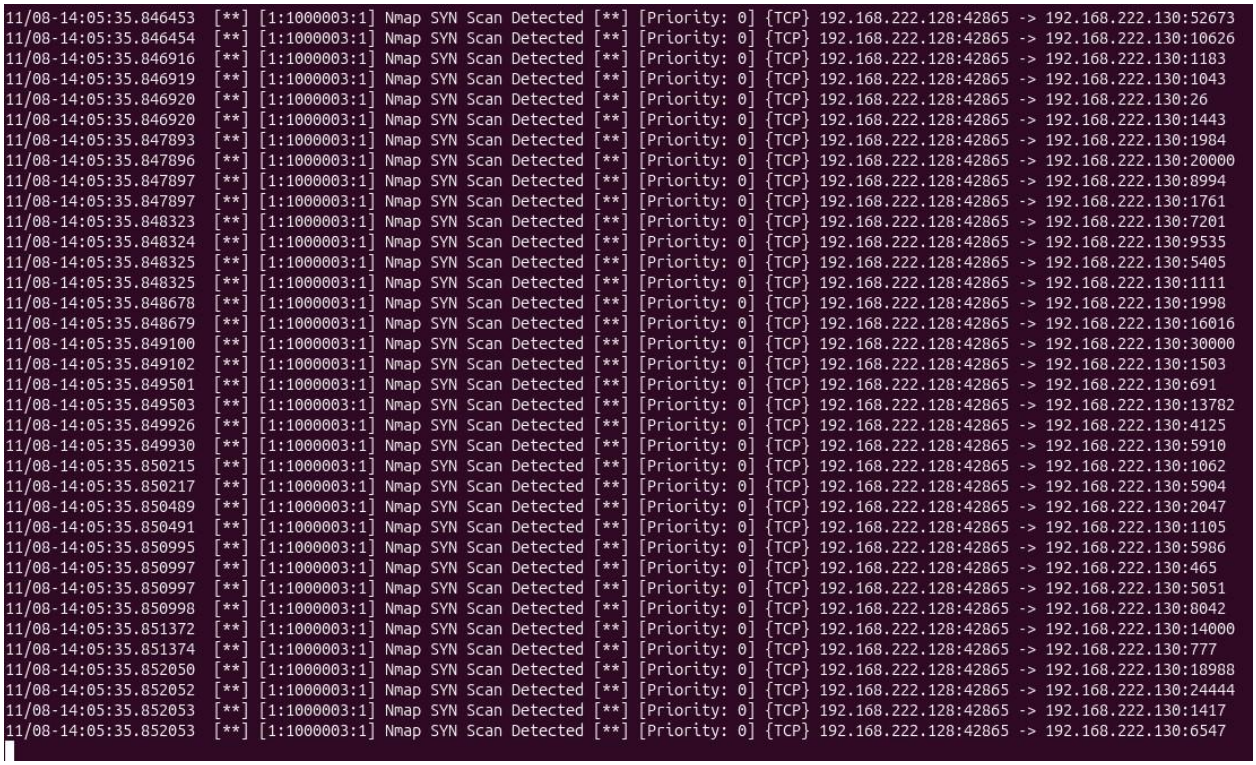


Figure 10 : alertes Nmap SYN Scan Detected générées par Snort

Snort génère une alerte pour chaque paquet SYN reçu, ce qui explique le grand nombre de lignes affichées d'un coup : un scan de ports envoie énormément de paquets en très peu de temps, et chacun déclenche la règle.

6.4 Tentative de connexion FTP

Depuis Kali, on tente une connexion FTP avec `ftp 192.168.222.130`.

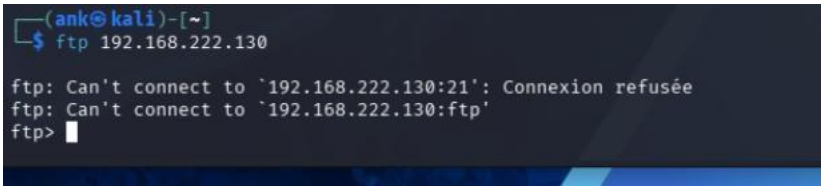


Figure 11 : connexion FTP refusée

Le message « Connection refused » montre qu'aucun service FTP n'est installé ou démarré sur Ubuntu. Comme pour le test HTTP, ce n'est pas un problème : la connexion est refusée par le système, mais la tentative, elle, a bien circulé sur le réseau jusqu'au port 21.

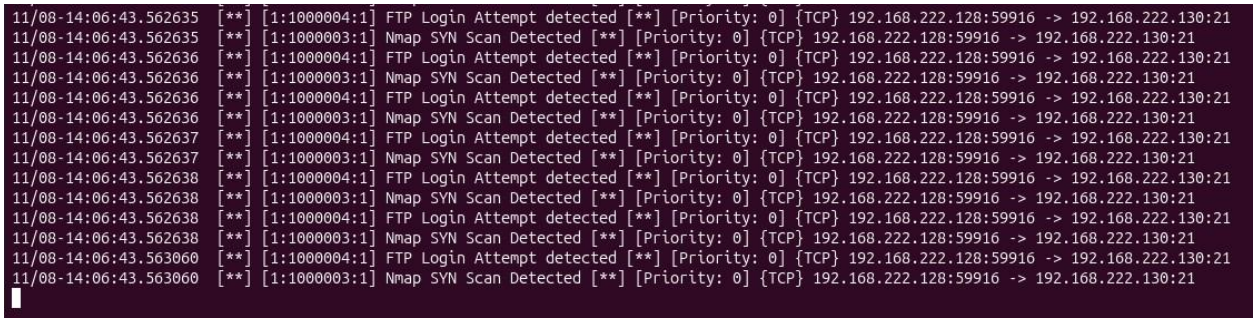


Figure 12 : alerte FTP Login Attempt detected générée par Snort

Snort détecte la tentative indépendamment du fait qu'un service réponde ou non derrière le port : il analyse les paquets qui transitent, pas l'état des services. L'alerte confirme donc que la règle fonctionne même sans serveur FTP actif.

6.5 Force brute sur SSH

Depuis Kali, l'outil Hydra teste automatiquement une liste de mots de passe sur le compte « ubuntu » via SSH, avec `hydra ssh://192.168.222.130 -l ubuntu -P <liste_de_mots_de_passe>`.

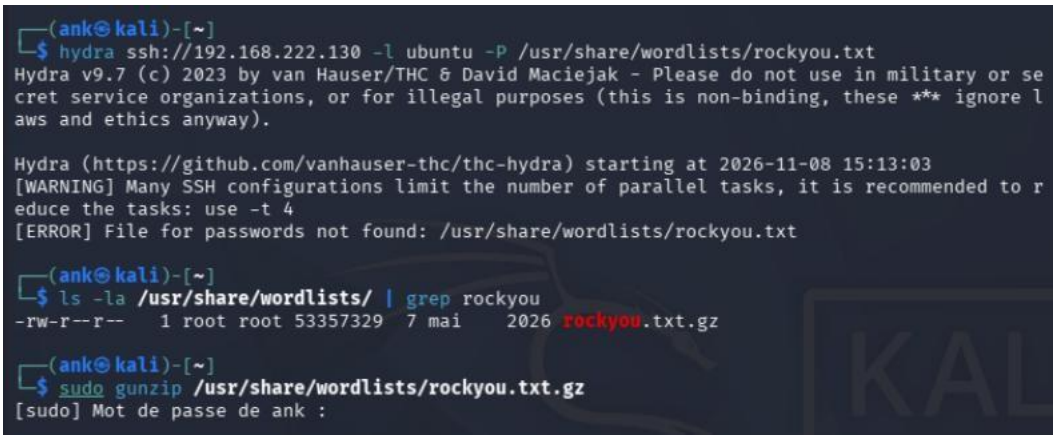
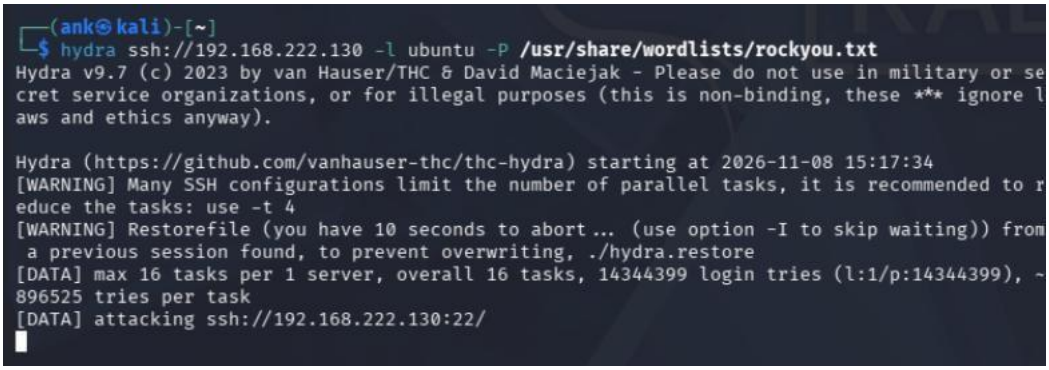


Figure 13 : lancement de l'attaque par force brute avec Hydra

Le fichier a été compresse , on decompresse avec gunzip



Hydra commence à essayer les mots de passe de la liste les uns après les autres, en se connectant plusieurs fois de suite sur le port SSH (22).

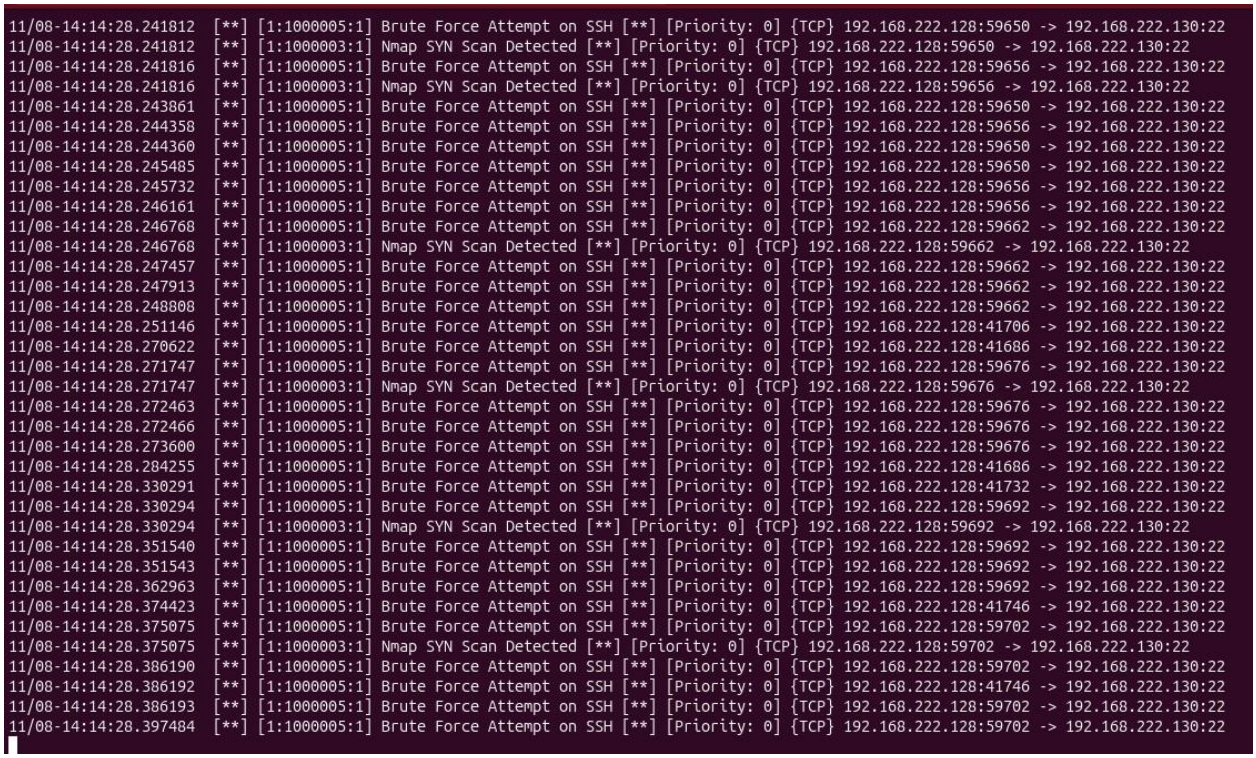


Figure 14 : alertes SSH générées par Snort pendant l'attaque

Deux types de lignes apparaissent : des alertes générales de connexion SSH, et surtout la ligne Brute Force Attempt on SSH, qui ne se déclenche qu'après 5 tentatives venant de la même adresse en moins de 30 secondes. C'est la preuve que la règle ne réagit pas à une simple connexion isolée, mais bien à un comportement répété et suspect.

7. Finalités du laboratoire et recommandations pour un analyste SOC

7.1 À quoi sert ce genre de laboratoire

Ce laboratoire reproduit, à petite échelle, une partie du travail quotidien d'un analyste SOC (Security Operations Center). Dans une vraie entreprise, un outil comme Snort tourne en permanence sur le réseau et génère des alertes 24h/24. Le rôle de l'analyste n'est pas d'écrire les règles une fois pour toutes, mais de surveiller ces alertes, de comprendre ce qu'elles signifient, de distinguer une vraie attaque d'un faux positif, et de décider rapidement d'une action : bloquer une adresse, remonter l'information, ou au contraire ignorer une alerte sans gravité.

Les cinq règles de ce rapport correspondent à des familles d'attaques réelles et très courantes : la reconnaissance (ping, scan de ports), l'exploitation d'une application web (accès à /etc/passwd), et l'attaque directe de services d'authentification (FTP, SSH). Savoir les reconnaître est la base de toute activité de surveillance réseau.

7.2 Recommandations par type d'alerte

Alerte Snort	Ce qu'elle indique	Action recommandée

ICMP PING detected	Une machine sonde la présence d'un hôte ; souvent anodin, mais peut précéder un scan plus poussé.	Surveiller si les pings se répètent ou viennent de plusieurs adresses à la fois (signe de reconnaissance à grande échelle).
Possible HTTP Attack	Tentative d'accès à un fichier sensible (/etc/passwd) via l'application web : signe de path traversal.	Vérifier les journaux du serveur web, s'assurer que l'application filtre les chemins d'accès, et mettre à jour ou patcher le code concerné. Un pare-feu applicatif (WAF) peut bloquer ce type de requête en amont.
Nmap SYN Scan Detected	Quelqu'un cartographie les ports ouverts de la machine : étape de reconnaissance avant une attaque ciblée.	Identifier l'adresse source et vérifier si elle est autorisée à scanner le réseau (test interne) ou non. Si elle est inconnue, la bloquer et surveiller si d'autres machines reçoivent le même scan.
FTP Login Attempt detected	Une connexion est tentée sur le port FTP.	Si le service FTP n'est pas utilisé, le désactiver et fermer le port. S'il est nécessaire, le remplacer par une solution chiffrée (SFTP) et limiter les adresses autorisées à s'y connecter.
Brute Force Attempt on SSH	Plusieurs tentatives de connexion rapprochées depuis la même adresse : tentative de deviner un mot de passe.	Bloquer l'adresse source (manuellement ou automatiquement avec un outil comme fail2ban), vérifier qu'aucune connexion n'a abouti, et renforcer l'authentification SSH (clé plutôt que mot de passe, désactivation de la connexion root, limitation du nombre de tentatives).

7.3 Recommandations générales

Au-delà de ces cinq cas précis, un analyste SOC applique en général les principes suivants :

- Vérifier l'adresse source avant d'agir : certaines alertes proviennent d'outils de test internes et ne sont pas de vraies attaques.
- Mettre en place un blocage automatique (pare-feu, IPS) pour les comportements clairement malveillants et répétés, plutôt que de bloquer manuellement chaque alerte.
- Centraliser les alertes dans un outil de corrélation (SIEM) plutôt que de lire chaque ligne de Snort une par une, surtout quand plusieurs capteurs sont déployés.
- Ajuster régulièrement les règles pour réduire les faux positifs, par exemple en limitant une règle trop générale (comme le scan SYN) à certains ports ou certains réseaux surveillés.
- Documenter chaque incident traité (date, adresse, règle déclenchée, action prise) pour garder une trace et détecter des tendances dans le temps.
- Désactiver les services inutilisés (FTP, par exemple) plutôt que de se contenter de les détecter : la meilleure défense est souvent de réduire la surface d'attaque.

- Tenir les signatures et règles à jour, car de nouvelles méthodes d'attaque apparaissent régulièrement.

8. Conclusion

Ce laboratoire a permis d'écrire et de tester cinq règles Snort couvrant des situations très différentes : une simple sonde réseau (ping), une tentative d'exploitation web (accès à /etc/passwd), un scan de reconnaissance (SYN), et deux attaques sur des services d'authentification (FTP, SSH). Dans chaque cas, Snort a généré une alerte contenant l'adresse de la machine attaquante, ce qui permettrait à un administrateur de réagir rapidement, par exemple en bloquant cette adresse.

Ce travail a aussi montré l'importance de bien relier les deux fichiers de configuration entre eux (HOME_NET, RULE_PATH et l'inclusion de local.rules) : une seule ligne manquante suffit à empêcher Snort de démarrer ou de détecter quoi que ce soit, même si les règles elles-mêmes sont correctement écrites.

Références

- https://www.snort.org
- Documentation officielle Snort – Writing Snort Rules